

Week 2 Task

Submitted By:

Muhammad Tayyab Nisar

Q No 1

Configuring snort

Please use the CIDR form - for example, 192.168.1.0/24 for a block of 256 addresses or 192.168.1.42/32 for just one. Multiple values should be comma-separated (without spaces).

Please note that if Snort is configured to use multiple interfaces, it will use this value as the HOME_NET definition for all of them.

Address range for the local network:

192.168.0.0/16

<Ok>

```
root@kali: /etc/snort
File Actions Edit View Help
GNU nano 8.1 snort.conf
#
# VRT Rule Packages Snort.conf
#
# For more information visit us at:
# http://www.snort.org           Snort Website
# http://vrt-blog.snort.org/     Sourcefire VRT Blog
#
# Mailing list Contact:      snort-sigs@lists.sourceforge.net
# False Positive reports:    fp@sourcefire.com
# Snort bugs:                bugs@snort.org
#
# Compatible with Snort Versions:
# VERSIONS : 2.9.7.0
#
# Snort build options:
# OPTIONS : --enable-gre --enable-mpls --enable-targetbased --enable-ppm --enable-perfprofiling --enable-zlib --enable-active-response --enable-...
#
# Additional information:
# This configuration file enables active response, to run snort in
# test mode -T you are required to supply an interface -i <interface>
# or test mode will fail to fully validate the configuration and
# exit with a FATAL error
#
#####
# This file contains a sample snort configuration.
# You should take the following steps to create your own custom configuration:
#
# 1) Set the network variables.
# 2) Configure the decoder
```

○ Smurf Attack

```
snort -A console -q -u snort -g snort -c /etc/snort/snort.conf -i eth1
09/27-03:03:32.893026 00000001:0 "ICMP message found" [Priority: 0] {ICMP} 150.1.7.104 → 150.1.7.255
09/27-03:03:32.893026 00000004:1 Smurf attack detected [Priority: 0] {ICMP} 150.1.7.104 → 150.1.7.255
09/27-03:03:33.893971 00000001:0 "ICMP message found" [Priority: 0] {ICMP} 150.1.7.104 → 150.1.7.255
09/27-03:03:33.893971 00000004:1 Smurf attack detected [Priority: 0] {ICMP} 150.1.7.104 → 150.1.7.255
09/27-03:03:34.895171 00000001:0 "ICMP message found" [Priority: 0] {ICMP} 150.1.7.104 → 150.1.7.255
09/27-03:03:34.895171 00000004:1 Smurf attack detected [Priority: 0] {ICMP} 150.1.7.104 → 150.1.7.255
09/27-03:03:35.896500 00000001:0 "ICMP message found" [Priority: 0] {ICMP} 150.1.7.104 → 150.1.7.255
09/27-03:03:35.896500 00000004:1 Smurf attack detected [Priority: 0] {ICMP} 150.1.7.104 → 150.1.7.255
09/27-03:03:36.897380 00000001:0 "ICMP message found" [Priority: 0] {ICMP} 150.1.7.104 → 150.1.7.255
09/27-03:03:36.897380 00000004:1 Smurf attack detected [Priority: 0] {ICMP} 150.1.7.104 → 150.1.7.255
09/27-03:03:37.899015 00000001:0 "ICMP message found" [Priority: 0] {ICMP} 150.1.7.104 → 150.1.7.255
09/27-03:03:37.899015 00000004:1 Smurf attack detected [Priority: 0] {ICMP} 150.1.7.104 → 150.1.7.255
09/27-03:03:38.915961 00000001:0 "ICMP message found" [Priority: 0] {ICMP} 150.1.7.104 → 150.1.7.255
09/27-03:03:38.915961 00000004:1 Smurf attack detected [Priority: 0] {ICMP} 150.1.7.104 → 150.1.7.255
09/27-03:03:39.917681 00000001:0 "ICMP message found" [Priority: 0] {ICMP} 150.1.7.104 → 150.1.7.255
09/27-03:03:39.917681 00000004:1 Smurf attack detected [Priority: 0] {ICMP} 150.1.7.104 → 150.1.7.255
09/27-03:03:40.919196 00000001:0 "ICMP message found" [Priority: 0] {ICMP} 150.1.7.104 → 150.1.7.255
09/27-03:03:40.919196 00000004:1 Smurf attack detected [Priority: 0] {ICMP} 150.1.7.104 → 150.1.7.255
09/27-03:03:41.920492 00000001:0 "ICMP message found" [Priority: 0] {ICMP} 150.1.7.104 → 150.1.7.255
09/27-03:03:41.920492 00000004:1 Smurf attack detected [Priority: 0] {ICMP} 150.1.7.104 → 150.1.7.255
09/27-03:03:42.921391 00000001:0 "ICMP message found" [Priority: 0] {ICMP} 150.1.7.104 → 150.1.7.255
09/27-03:03:42.921391 00000004:1 Smurf attack detected [Priority: 0] {ICMP} 150.1.7.104 → 150.1.7.255
09/27-03:03:43.922164 00000001:0 "ICMP message found" [Priority: 0] {ICMP} 150.1.7.104 → 150.1.7.255
09/27-03:03:43.922164 00000004:1 Smurf attack detected [Priority: 0] {ICMP} 150.1.7.104 → 150.1.7.255
09/27-03:03:44.924266 00000001:0 "ICMP message found" [Priority: 0] {ICMP} 150.1.7.104 → 150.1.7.255
09/27-03:03:44.924266 00000004:1 Smurf attack detected [Priority: 0] {ICMP} 150.1.7.104 → 150.1.7.255
09/27-03:03:45.925697 00000001:0 "ICMP message found" [Priority: 0] {ICMP} 150.1.7.104 → 150.1.7.255
09/27-03:03:45.925697 00000004:1 Smurf attack detected [Priority: 0] {ICMP} 150.1.7.104 → 150.1.7.255
09/27-03:03:46.927041 00000001:0 "ICMP message found" [Priority: 0] {ICMP} 150.1.7.104 → 150.1.7.255
09/27-03:03:46.927041 00000004:1 Smurf attack detected [Priority: 0] {ICMP} 150.1.7.104 → 150.1.7.255
09/27-03:03:47.928213 00000001:0 "ICMP message found" [Priority: 0] {ICMP} 150.1.7.104 → 150.1.7.255
09/27-03:03:47.928213 00000004:1 Smurf attack detected [Priority: 0] {ICMP} 150.1.7.104 → 150.1.7.255
```

○ DNS Poisoning / Amplification Attack

```
# LOCAL RULES
#
# This file intentionally does not come with signatures. Put your local
# additions here.
alert icmp any any → 150.1.7.0/24 any (msg:"ICMP message found";sid:10000001;)
alert tcp any any → 150.1.7.0/24 80 (msg:"Potential SYN Flood Attack"; flags:S; threshold:type threshold, track by_src, count 100, seconds 10;)
alert tcp 150.1.7.0/24 any → 150.1.7.0/24 any (msg:"LAND Attack Detected"; flags:S; dsize:0; sid:10000003; rev:1;)
alert icmp 150.1.7.0/24 any → 150.1.7.0/24 any (msg:"Smurf attack detected"; itype:8; sid:10000004; rev:1;)
alert udp 150.1.7.0/24 any → 150.1.7.0/24 53 (msg:"DNS Poisoning Attack Detected"; content:"|00 01 00 01|"; offset:2; depth:4; sid:10000005;)
alert udp any any → 150.1.7.0/24 53 (msg:"DNS Amplification Attack Detected"; threshold:type limit, track by_src, count 10, seconds 1; sid:10000006;)
```

```
(root@kali)-[/etc/snort]
# snort -A console -q -u snort -g snort -c /etc/snort/snort.conf -i eth1
09/27-03:31:49.631923 [[*]] [1:1000006:1] DNS Amplification Attack Detected [[*]] [Priority: 0] {UDP} 150.1.7.101:2657 → 150.1.7.104:53
09/27-03:31:50.632861 [[*]] [1:1000006:1] DNS Amplification Attack Detected [[*]] [Priority: 0] {UDP} 150.1.7.101:2658 → 150.1.7.104:53
09/27-03:31:51.634115 [[*]] [1:1000006:1] DNS Amplification Attack Detected [[*]] [Priority: 0] {UDP} 150.1.7.101:2659 → 150.1.7.104:53
09/27-03:31:52.635234 [[*]] [1:1000006:1] DNS Amplification Attack Detected [[*]] [Priority: 0] {UDP} 150.1.7.101:2660 → 150.1.7.104:53
09/27-03:31:53.635800 [[*]] [1:1000006:1] DNS Amplification Attack Detected [[*]] [Priority: 0] {UDP} 150.1.7.101:2661 → 150.1.7.104:53
09/27-03:31:54.636827 [[*]] [1:1000006:1] DNS Amplification Attack Detected [[*]] [Priority: 0] {UDP} 150.1.7.101:2662 → 150.1.7.104:53
09/27-03:31:55.637782 [[*]] [1:1000006:1] DNS Amplification Attack Detected [[*]] [Priority: 0] {UDP} 150.1.7.101:2663 → 150.1.7.104:53
09/27-03:31:56.638423 [[*]] [1:1000006:1] DNS Amplification Attack Detected [[*]] [Priority: 0] {UDP} 150.1.7.101:2664 → 150.1.7.104:53
09/27-03:31:57.639567 [[*]] [1:1000006:1] DNS Amplification Attack Detected [[*]] [Priority: 0] {UDP} 150.1.7.101:2665 → 150.1.7.104:53
09/27-03:31:58.640667 [[*]] [1:1000006:1] DNS Amplification Attack Detected [[*]] [Priority: 0] {UDP} 150.1.7.101:2666 → 150.1.7.104:53
09/27-03:31:59.641891 [[*]] [1:1000006:1] DNS Amplification Attack Detected [[*]] [Priority: 0] {UDP} 150.1.7.101:2667 → 150.1.7.104:53
09/27-03:32:00.642317 [[*]] [1:1000006:1] DNS Amplification Attack Detected [[*]] [Priority: 0] {UDP} 150.1.7.101:2668 → 150.1.7.104:53
09/27-03:32:01.643136 [[*]] [1:1000006:1] DNS Amplification Attack Detected [[*]] [Priority: 0] {UDP} 150.1.7.101:2669 → 150.1.7.104:53
09/27-03:32:02.643670 [[*]] [1:1000006:1] DNS Amplification Attack Detected [[*]] [Priority: 0] {UDP} 150.1.7.101:2670 → 150.1.7.104:53
09/27-03:32:03.644750 [[*]] [1:1000006:1] DNS Amplification Attack Detected [[*]] [Priority: 0] {UDP} 150.1.7.101:2671 → 150.1.7.104:53
09/27-03:32:04.645475 [[*]] [1:1000006:1] DNS Amplification Attack Detected [[*]] [Priority: 0] {UDP} 150.1.7.101:2672 → 150.1.7.104:53
09/27-03:32:05.646590 [[*]] [1:1000006:1] DNS Amplification Attack Detected [[*]] [Priority: 0] {UDP} 150.1.7.101:2673 → 150.1.7.104:53
09/27-03:32:06.647507 [[*]] [1:1000006:1] DNS Amplification Attack Detected [[*]] [Priority: 0] {UDP} 150.1.7.101:2674 → 150.1.7.104:53
09/27-03:32:07.648407 [[*]] [1:1000006:1] DNS Amplification Attack Detected [[*]] [Priority: 0] {UDP} 150.1.7.101:2675 → 150.1.7.104:53
09/27-03:32:08.649145 [[*]] [1:1000006:1] DNS Amplification Attack Detected [[*]] [Priority: 0] {UDP} 150.1.7.101:2676 → 150.1.7.104:53
09/27-03:32:09.650072 [[*]] [1:1000006:1] DNS Amplification Attack Detected [[*]] [Priority: 0] {UDP} 150.1.7.101:2677 → 150.1.7.104:53
09/27-03:32:10.651200 [[*]] [1:1000006:1] DNS Amplification Attack Detected [[*]] [Priority: 0] {UDP} 150.1.7.101:2678 → 150.1.7.104:53
09/27-03:32:11.651982 [[*]] [1:1000006:1] DNS Amplification Attack Detected [[*]] [Priority: 0] {UDP} 150.1.7.101:2679 → 150.1.7.104:53
09/27-03:32:12.652822 [[*]] [1:1000006:1] DNS Amplification Attack Detected [[*]] [Priority: 0] {UDP} 150.1.7.101:2680 → 150.1.7.104:53
09/27-03:32:13.653657 [[*]] [1:1000006:1] DNS Amplification Attack Detected [[*]] [Priority: 0] {UDP} 150.1.7.101:2681 → 150.1.7.104:53
09/27-03:32:14.654804 [[*]] [1:1000006:1] DNS Amplification Attack Detected [[*]] [Priority: 0] {UDP} 150.1.7.101:2682 → 150.1.7.104:53
09/27-03:32:15.655763 [[*]] [1:1000006:1] DNS Amplification Attack Detected [[*]] [Priority: 0] {UDP} 150.1.7.101:2683 → 150.1.7.104:53
09/27-03:32:16.656558 [[*]] [1:1000006:1] DNS Amplification Attack Detected [[*]] [Priority: 0] {UDP} 150.1.7.101:2684 → 150.1.7.104:53
09/27-03:32:17.657696 [[*]] [1:1000006:1] DNS Amplification Attack Detected [[*]] [Priority: 0] {UDP} 150.1.7.101:2685 → 150.1.7.104:53
09/27-03:32:18.658777 [[*]] [1:1000006:1] DNS Amplification Attack Detected [[*]] [Priority: 0] {UDP} 150.1.7.101:2686 → 150.1.7.104:53
09/27-03:32:19.659493 [[*]] [1:1000006:1] DNS Amplification Attack Detected [[*]] [Priority: 0] {UDP} 150.1.7.101:2687 → 150.1.7.104:53
09/27-03:32:20.660551 [[*]] [1:1000006:1] DNS Amplification Attack Detected [[*]] [Priority: 0] {UDP} 150.1.7.101:2688 → 150.1.7.104:53
```

○ Ping of Death Attack

```
GNU nano 8.1 /etc/snort/rules/local.rules
# $Id: local.rules,v 1.11 2004/07/23 20:15:44 bmc Exp $
#
# LOCAL RULES
#
# This file intentionally does not come with signatures. Put your local
# additions here.
alert icmp any any → 150.1.7.0/24 any (msg:"ICMP message found";sid:10000001;)
alert tcp any any → 150.1.7.0/24 80 (msg:"Potential SYN Flood Attack"; flags:S; threshold:type threshold, track by_src, count 100, seconds 10;)
alert tcp 150.1.7.0/24 any → 150.1.7.0/24 any (msg:"LAND Attack Detected"; flags:S; dsize:0; sid:10000003; rev:1;)
alert icmp 150.1.7.0/24 any → 150.1.7.0/24 any (msg:"Smurf attack detected"; itype:8; sid:10000004; rev:1;)
alert udp 150.1.7.0/24 any → 150.1.7.0/24 53 (msg:"DNS Poisoning Attack Detected"; content:"|00 01 00 01|"; offset:2; depth:4; sid:10000005;)
alert udp any any → 150.1.7.0/24 53 (msg:"DNS Amplification Attack Detected"; threshold:type limit, track by_src, count 10, seconds 1; sid:10000006;)
alert icmp any any → 150.1.7.0/24 any (msg:"Ping of Death detected"; itype:8; dsize:>1400; sid:10000007; rev:1;)
```

```
(root@kali)-[/etc/snort]
# snort -A console -q -u snort -g snort -c /etc/snort/snort.conf -i eth1
09/27-03:50:01.285015 [[*]] [1:1000007:1] "ICMP message found" [[*]] [Priority: 0] {ICMP} 150.1.7.101 → 150.1.7.104
09/27-03:50:01.285015 [[*]] [1:1000007:1] Ping of Death detected [[*]] [Priority: 0] {ICMP} 150.1.7.101 → 150.1.7.104
09/27-03:50:01.285015 [[*]] [1:1000004:1] Smurf attack detected [[*]] [Priority: 0] {ICMP} 150.1.7.101 → 150.1.7.104
09/27-03:50:02.289055 [[*]] [1:1000001:0] "ICMP message found" [[*]] [Priority: 0] {ICMP} 150.1.7.101 → 150.1.7.104
09/27-03:50:02.289055 [[*]] [1:1000007:1] Ping of Death detected [[*]] [Priority: 0] {ICMP} 150.1.7.101 → 150.1.7.104
09/27-03:50:02.289055 [[*]] [1:1000004:1] Smurf attack detected [[*]] [Priority: 0] {ICMP} 150.1.7.101 → 150.1.7.104
09/27-03:50:02.309160 [[*]] [1:1000001:0] "ICMP message found" [[*]] [Priority: 0] {ICMP} 150.1.7.101 → 150.1.7.104
09/27-03:50:03.290878 [[*]] [1:1000001:0] "ICMP message found" [[*]] [Priority: 0] {ICMP} 150.1.7.101 → 150.1.7.104
09/27-03:50:03.290878 [[*]] [1:1000007:1] Ping of Death detected [[*]] [Priority: 0] {ICMP} 150.1.7.101 → 150.1.7.104
09/27-03:50:03.290878 [[*]] [1:1000004:1] Smurf attack detected [[*]] [Priority: 0] {ICMP} 150.1.7.101 → 150.1.7.104
09/27-03:50:03.292866 [[*]] [1:1000001:0] "ICMP message found" [[*]] [Priority: 0] {ICMP} 150.1.7.101 → 150.1.7.101
09/27-03:50:04.293599 [[*]] [1:1000001:0] "ICMP message found" [[*]] [Priority: 0] {ICMP} 150.1.7.101 → 150.1.7.104
09/27-03:50:04.293599 [[*]] [1:1000007:1] Ping of Death detected [[*]] [Priority: 0] {ICMP} 150.1.7.101 → 150.1.7.104
09/27-03:50:04.293599 [[*]] [1:1000004:1] Smurf attack detected [[*]] [Priority: 0] {ICMP} 150.1.7.101 → 150.1.7.104
09/27-03:50:04.296303 [[*]] [1:1000001:0] "ICMP message found" [[*]] [Priority: 0] {ICMP} 150.1.7.101 → 150.1.7.101
09/27-03:50:05.296053 [[*]] [1:1000001:0] "ICMP message found" [[*]] [Priority: 0] {ICMP} 150.1.7.101 → 150.1.7.104
09/27-03:50:05.296053 [[*]] [1:1000007:1] Ping of Death detected [[*]] [Priority: 0] {ICMP} 150.1.7.101 → 150.1.7.104
09/27-03:50:05.296053 [[*]] [1:1000004:1] Smurf attack detected [[*]] [Priority: 0] {ICMP} 150.1.7.101 → 150.1.7.104
09/27-03:50:05.298227 [[*]] [1:1000001:0] "ICMP message found" [[*]] [Priority: 0] {ICMP} 150.1.7.101 → 150.1.7.101
09/27-03:50:06.297910 [[*]] [1:1000001:0] "ICMP message found" [[*]] [Priority: 0] {ICMP} 150.1.7.101 → 150.1.7.104
09/27-03:50:06.297910 [[*]] [1:1000007:1] Ping of Death detected [[*]] [Priority: 0] {ICMP} 150.1.7.101 → 150.1.7.104
09/27-03:50:06.297910 [[*]] [1:1000004:1] Smurf attack detected [[*]] [Priority: 0] {ICMP} 150.1.7.101 → 150.1.7.104
09/27-03:50:06.299856 [[*]] [1:1000001:0] "ICMP message found" [[*]] [Priority: 0] {ICMP} 150.1.7.101 → 150.1.7.101
09/27-03:50:07.297838 [[*]] [1:1000001:0] "ICMP message found" [[*]] [Priority: 0] {ICMP} 150.1.7.101 → 150.1.7.104
09/27-03:50:07.297838 [[*]] [1:1000007:1] Ping of Death detected [[*]] [Priority: 0] {ICMP} 150.1.7.101 → 150.1.7.104
09/27-03:50:07.297838 [[*]] [1:1000004:1] Smurf attack detected [[*]] [Priority: 0] {ICMP} 150.1.7.101 → 150.1.7.104
09/27-03:50:07.299893 [[*]] [1:1000001:0] "ICMP message found" [[*]] [Priority: 0] {ICMP} 150.1.7.101 → 150.1.7.101
09/27-03:50:08.300124 [[*]] [1:1000001:0] "ICMP message found" [[*]] [Priority: 0] {ICMP} 150.1.7.101 → 150.1.7.104
09/27-03:50:08.300124 [[*]] [1:1000007:1] Ping of Death detected [[*]] [Priority: 0] {ICMP} 150.1.7.101 → 150.1.7.104
```

○ UDP Flood Attack

```
# $Id: local.rules,v 1.11 2004/07/23 20:15:44 bmc Exp $
#
# LOCAL RULES
#
# This file intentionally does not come with signatures.  Put your local
# additions here.
alert icmp any any → 150.1.7.0/24 any (msg: "ICMP message found";sid:10000001;)
alert tcp any any → 150.1.7.0/24 80 (msg:"Potential SYN Flood Attack"; flags:S; threshold:type threshold, track by_src, count 100, seconds 10)
alert tcp 150.1.7.0/24 any → 150.1.7.0/24 any (msg:"LAND Attack Detected"; flags:S; dsize:0; sid:10000003; rev:1;)
alert icmp 150.1.7.0/24 any → 150.1.7.0/24 any (msg:"Smurf attack detected"; itype:8; sid:10000004; rev:1;)
alert udp 150.1.7.0/24 any → 150.1.7.0/24 53 (msg:"DNS Poisoning Attack Detected"; content:"|00 01 00 01|"; offset:2; depth:4; sid:10000005;)
alert udp any any → 150.1.7.0/24 53 (msg:"DNS Amplification Attack Detected"; threshold:type limit, track by_src, count 10, seconds 1; sid:10)
alert icmp any any → 150.1.7.0/24 any (msg:"Ping of Death detected"; itype:8; dsize:>1400; sid:10000007; rev:1;)
alert udp any any → 150.1.7.0/24 any (msg:"UDP Flood attack detected"; threshold:type both, track by_src, count 50, seconds 1; sid:10000008;
```

```
09/27-12:49:16.003388 [**] [1:10000008:1] UDP Flood attack detected [**] [Priority: 0] {UDP} 150.1.7.101:12068 → 150.1.7.104:53
09/27-12:49:17.000061 [**] [1:10000006:1] DNS Amplification Attack Detected [**] [Priority: 0] {UDP} 150.1.7.101:26285 → 150.1.7.104:53
09/27-12:49:17.000108 [**] [1:10000006:1] DNS Amplification Attack Detected [**] [Priority: 0] {UDP} 150.1.7.101:26286 → 150.1.7.104:53
09/27-12:49:17.000186 [**] [1:10000006:1] DNS Amplification Attack Detected [**] [Priority: 0] {UDP} 150.1.7.101:26287 → 150.1.7.104:53
09/27-12:49:17.000210 [**] [1:10000006:1] DNS Amplification Attack Detected [**] [Priority: 0] {UDP} 150.1.7.101:26288 → 150.1.7.104:53
09/27-12:49:17.000287 [**] [1:10000006:1] DNS Amplification Attack Detected [**] [Priority: 0] {UDP} 150.1.7.101:26289 → 150.1.7.104:53
09/27-12:49:17.000302 [**] [1:10000006:1] DNS Amplification Attack Detected [**] [Priority: 0] {UDP} 150.1.7.101:26290 → 150.1.7.104:53
09/27-12:49:17.000417 [**] [1:10000006:1] DNS Amplification Attack Detected [**] [Priority: 0] {UDP} 150.1.7.101:26291 → 150.1.7.104:53
09/27-12:49:17.000437 [**] [1:10000006:1] DNS Amplification Attack Detected [**] [Priority: 0] {UDP} 150.1.7.101:26292 → 150.1.7.104:53
09/27-12:49:17.000506 [**] [1:10000006:1] DNS Amplification Attack Detected [**] [Priority: 0] {UDP} 150.1.7.101:26293 → 150.1.7.104:53
09/27-12:49:17.000522 [**] [1:10000006:1] DNS Amplification Attack Detected [**] [Priority: 0] {UDP} 150.1.7.101:26294 → 150.1.7.104:53
09/27-12:49:17.003143 [**] [1:10000008:1] UDP Flood attack detected [**] [Priority: 0] {UDP} 150.1.7.101:26334 → 150.1.7.104:53
09/27-12:49:18.000032 [**] [1:10000006:1] DNS Amplification Attack Detected [**] [Priority: 0] {UDP} 150.1.7.101:41018 → 150.1.7.104:53
09/27-12:49:18.000056 [**] [1:10000006:1] DNS Amplification Attack Detected [**] [Priority: 0] {UDP} 150.1.7.101:41019 → 150.1.7.104:53
```

○ Hping3 with UDP Flood Attack

```
(root@kali)-[/home/kali]
# hping3 --flood --udp -p 53 150.1.7.104
HPING 150.1.7.104 (eth1 150.1.7.104): udp mode set, 28 headers + 0 data bytes
hping in flood mode, no replies will be shown
```

Q No 2

Step 1: Install dependencies for Google Authenticator Module

```
apt-get install libpam0g-dev
```

```
root@kali: ~
File Edit View Search Terminal Help
root@kali:~#
root@kali:~# apt-get install libpam0g-dev make
Reading package lists... Done
Building dependency tree
Reading state information... Done
make is already the newest version.
make set to manually installed
The following NEW packages will be installed:
  libpam0g-dev
0 upgraded, 1 newly installed, 0 to remove and 0 not upgraded.
Need to get 191 kB of archives.
After this operation, 401 kB of additional disk space will be used.
Do you want to continue [Y/n]? Y
Get:1 http://http.kali.org/kali/ kali/main libpam0g-dev amd64 1.1.3-7.1 [191 kB]
Fetched 191 kB in 5s (36.2 kB/s)
Selecting previously unselected package libpam0g-dev:amd64.
(Reading database ... 370322 files and directories currently installed.)
Unpacking libpam0g-dev:amd64 (from .../libpam0g-dev_1.1.3-7.1_amd64.deb) ...
Processing triggers for man-db ...
Setting up libpam0g-dev:amd64 (1.1.3-7.1) ...
root@kali:~#
```



```
yum install pam-devel

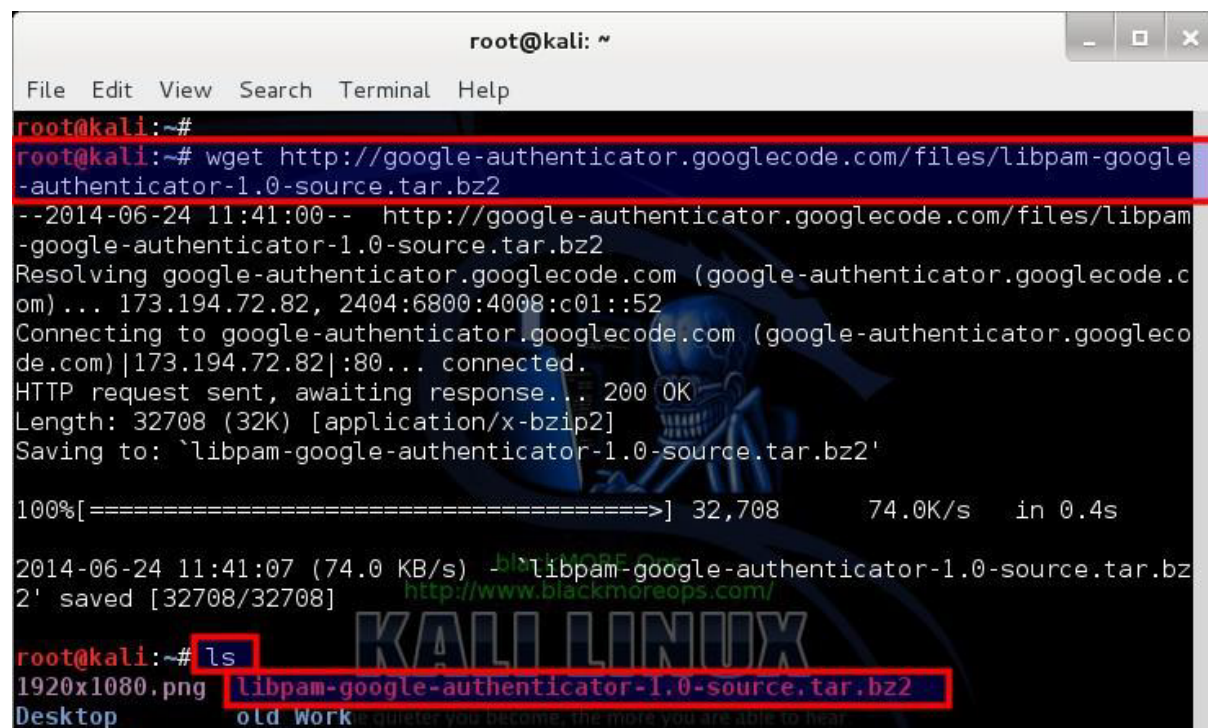
yum install make gcc wget

(or)

apt-get install make gcc wget
```

Step 2: Download Google Authenticator Module

```
root@kali:~# wget http://google-authenticator.googlecode.com/files/libpam-google-authenticator-1.0-source.tar.bz2
```

A screenshot of a Kali Linux terminal window. The window title is 'root@kali: ~'. The terminal shows the execution of the 'wget' command to download the Google Authenticator module source code. The download progress is shown as 100% completed. The file is saved as 'libpam-google-authenticator-1.0-source.tar.bz2'. The terminal also shows the 'ls' command being executed, listing the files in the current directory, which includes '1920x1080.png', 'Desktop', and 'old_work'. The file 'libpam-google-authenticator-1.0-source.tar.bz2' is highlighted in red. The terminal background features a Kali Linux logo and the text 'KALI LINUX' and 'the quieter you become, the more you are able to hear.'

```
root@kali:~# wget http://google-authenticator.googlecode.com/files/libpam-google-authenticator-1.0-source.tar.bz2
--2014-06-24 11:41:00-- http://google-authenticator.googlecode.com/files/libpam-google-authenticator-1.0-source.tar.bz2
Resolving google-authenticator.googlecode.com (google-authenticator.googlecode.com)... 173.194.72.82, 2404:6800:4008:c01::52
Connecting to google-authenticator.googlecode.com (google-authenticator.googlecode.com)|173.194.72.82|:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 32708 (32K) [application/x-bzip2]
Saving to: `libpam-google-authenticator-1.0-source.tar.bz2'

100%[=====>] 32,708      74.0K/s   in 0.4s

2014-06-24 11:41:07 (74.0 KB/s) `libpam-google-authenticator-1.0-source.tar.bz2' saved [32708/32708]

root@kali:~# ls
1920x1080.png  libpam-google-authenticator-1.0-source.tar.bz2
Desktop       old_work
```

```
root@kali:~# tar -xvf libpam-google-authenticator-1.0-source.tar.bz2

root@kali:~# cd libpam-google-authenticator-1.0/
```

```
root@kali: ~/libpam-google-authenticator-1.0
File Edit View Search Terminal Help
root@kali:~#
root@kali:~# tar -xvf libpam-google-authenticator-1.0-source.tar.bz2
libpam-google-authenticator-1.0/base32.c
libpam-google-authenticator-1.0/demo.c
libpam-google-authenticator-1.0/google-authenticator.c
libpam-google-authenticator-1.0/hmac.c
libpam-google-authenticator-1.0/pam_google_authenticator.c
libpam-google-authenticator-1.0/pam_google_authenticator_unittest.c
libpam-google-authenticator-1.0/sha1.c
libpam-google-authenticator-1.0/base32.h
libpam-google-authenticator-1.0/hmac.h
libpam-google-authenticator-1.0/sha1.h
libpam-google-authenticator-1.0/totp.html
libpam-google-authenticator-1.0/Makefile
libpam-google-authenticator-1.0/FILEFORMAT
libpam-google-authenticator-1.0/README
libpam-google-authenticator-1.0/utc-time/
libpam-google-authenticator-1.0/utc-time/app.yaml
libpam-google-authenticator-1.0/utc-time/utc-time.py
root@kali:~#
root@kali:~# cd libpam-google-authenticator-1.0/
root@kali:~/libpam-google-authenticator-1.0#
```

Step 3: Compile and Install Google Authenticator PAM module

```
root@kali:~/libpam-google-authenticator-1.0# make
```

```
root@kali: ~/libpam-google-authenticator-1.0
File Edit View Search Terminal Help
root@kali:~/libpam-google-authenticator-1.0#
root@kali:~/libpam-google-authenticator-1.0# make
gcc --std=gnu99 -Wall -O2 -g -fPIC -c -fvisibility=hidden -o google-authenticator.o google-authenticator.c
gcc --std=gnu99 -Wall -O2 -g -fPIC -c -fvisibility=hidden -o base32.o base32.c
gcc --std=gnu99 -Wall -O2 -g -fPIC -c -fvisibility=hidden -o hmac.o hmac.c
gcc --std=gnu99 -Wall -O2 -g -fPIC -c -fvisibility=hidden -o sha1.o sha1.c
gcc -g -o google-authenticator google-authenticator.o base32.o hmac.o sha1.o -ldl
gcc --std=gnu99 -Wall -O2 -g -fPIC -c -fvisibility=hidden -o pam_google_authenticator.o pam_google_authenticator.c
gcc -shared -g -o pam_google_authenticator.so pam_google_authenticator.o base32.o hmac.o sha1.o -lpam
gcc --std=gnu99 -Wall -O2 -g -fPIC -c -fvisibility=hidden -o demo.o demo.c
gcc -DDEMO --std=gnu99 -Wall -O2 -g -fPIC -c -fvisibility=hidden -o pam_google_authenticator_demo.o pam_google_authenticator.c
gcc -g -rdynamic -o demo demo.o pam_google_authenticator_demo.o base32.o hmac.o sha1.o -ldl
gcc -DTESTING --std=gnu99 -Wall -O2 -g -fPIC -c -fvisibility=hidden -o pam_google_authenticator_testing.o pam_google_authenticator.c
gcc -shared -g -o pam_google_authenticator_testing.so pam_google_authenticator_testing.o base32.o hmac.o sha1.o -lpam
gcc --std=gnu99 -Wall -O2 -g -fPIC -c -fvisibility=hidden -o pam_google_authenticator_unittest.o pam_google_authenticator_unittest.c
gcc -g -rdynamic -o pam_google_authenticator_unittest pam_google_authenticator_unittest.o base32.o hmac.o sha1.o -lc -ldl
root@kali:~/libpam-google-authenticator-1.0#
```

```
root@kali:~/libpam-google-authenticator-1.0# make install
```

```
root@kali: ~/libpam-google-authenticator-1.0
```

```
File Edit View Search Terminal Help
```

```
root@kali:~/libpam-google-authenticator-1.0#  
root@kali:~/libpam-google-authenticator-1.0# make install  
cp pam_google_authenticator.so /lib/x86_64-linux-gnu/security  
cp google-authenticator /usr/local/bin  
root@kali:~/libpam-google-authenticator-1.0#
```

Step 4: Run and configure Google Authenticator

```
root@kali:~/libpam-google-authenticator-1.0# google-authenticator
```

```
Do you want authentication tokens to be time-based (y/n) y
```

```
https://www.google.com/chart?chs=200x200&chld=M|0&cht=qr&chl=otpauth://totp/root@kali%3Fsecret%3DWKHM6UVJNTPYSPTQ
```

```
Your new secret key is: WKHM6UVJNTPYSPTQ
```

```
Your verification code is 434260
```

```
Your emergency scratch codes are:
```

```
30287010
```

```
70585905
```

```
68748337
```

```
15176712
```

```
38041521
```

```
Do you want me to update your "/root/.google_authenticator" file (y/n) y
```

```
Do you want to disallow multiple uses of the same authentication
```

```
token? This restricts you to one login about every 30s, but it increases
```

```
your chances to notice or even prevent man-in-the-middle attacks (y/n) y
```

```
possible time-skew between the client and the server, we allow an extra
```

```
token before and after the current time. If you experience problems with poor
```



```
time synchronization, you can increase the window from its default

If the computer that you are logging into isn't hardened against brute-force

login attempts, you can enable rate-limiting for the authentication module.

By default, this limits attackers to no more than 3 login attempts every 30s.

Do you want to enable rate-limiting (y/n) y
```

```
root@kali: ~/libpam-google-authenticator-1.0
File Edit View Search Terminal Help
root@kali:~/libpam-google-authenticator-1.0# google-authenticator
Do you want authentication tokens to be time-based (y/n) y
https://www.google.com/chart?chs=200x200&chld=M|0&cht=qr&chl=otpauth://totp/root
@kali%3Fsecret%3DWKHM6UVJNTPYSPT0
Your new secret key is: WKHM6UVJNTPYSPT0
Your verification code is 434260
Your emergency scratch codes are:
30287010
70585905
68748337
15176712
38041521

Do you want me to update your "/root/.google_authenticator" file (y/n) y
Do you want to disallow multiple uses of the same authentication
token? This restricts you to one login about every 30s, but it increases
your chances to notice or even prevent man-in-the-middle attacks (y/n) y

By default, tokens are good for 30 seconds and in order to compensate for
possible time-skew between the client and the server, we allow an extra
token before and after the current time. If you experience problems with poor
time synchronization, you can increase the window from its default
size of 1:30min to about 4min. Do you want to do so (y/n) y

If the computer that you are logging into isn't hardened against brute-force
login attempts, you can enable rate-limiting for the authentication module.
By default, this limits attackers to no more than 3 login attempts every 30s.
Do you want to enable rate-limiting (y/n) y
root@kali:~/libpam-google-authenticator-1.0#
```

Step 5: Configure SSH to use Google Authenticator PAM Module

```
root@kali:~# vi /etc/pam.d/sshd

auth          required      pam_google_authenticator.so
```



```
root@kali: ~/libpam-google-authenticator-1.0
File Edit View Search Terminal Help
# PAM configuration for the Secure Shell service
# Read environment variables from /etc/environment and
# /etc/security/pam env.conf.
auth      required      pam google authenticator.so
auth      required      pam_env.so # [1]
# In Debian 4.0 (etch), locale-related environment variables were moved to
# /etc/default/locale, so read that as well.
auth      required      pam_env.so envfile=/etc/default/locale
```

```
root@kali:~# vi /etc/ssh/sshd_config

ChallengeResponseAuthentication no

(change it to)

ChallengeResponseAuthentication yes
```

```
root@kali: ~/libpam-google-authenticator-1.0
File Edit View Search Terminal Help
RhostsRSAAuthentication no
# similar for protocol version 2
HostbasedAuthentication no
# Uncomment if you don't trust ~/.ssh/known_hosts for RhostsRSAAuthentication
#IgnoreUserKnownHosts yes

# To enable empty passwords, change to yes (NOT RECOMMENDED)
PermitEmptyPasswords no

# Change to yes to enable challenge-response passwords (beware issues with
# some PAM modules and threads)
ChallengeResponseAuthentication yes

# Change to no to disable tunnelled clear text passwords
#PasswordAuthentication yes
```

```
service ssh restart

(or)

service sshd restart

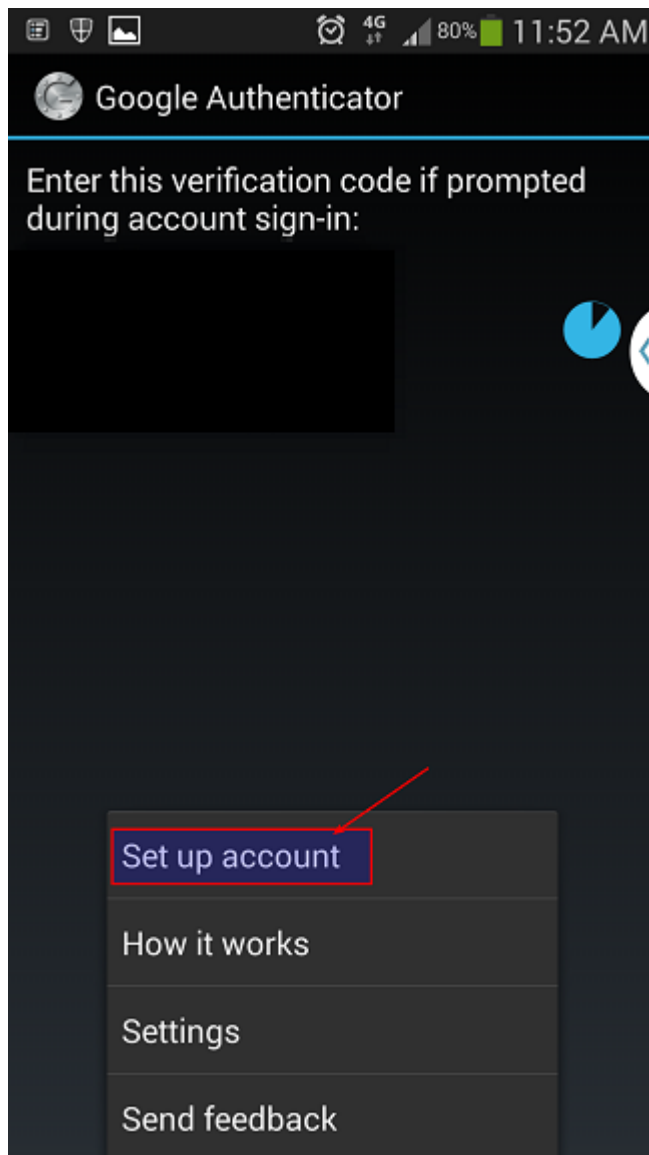
(or)

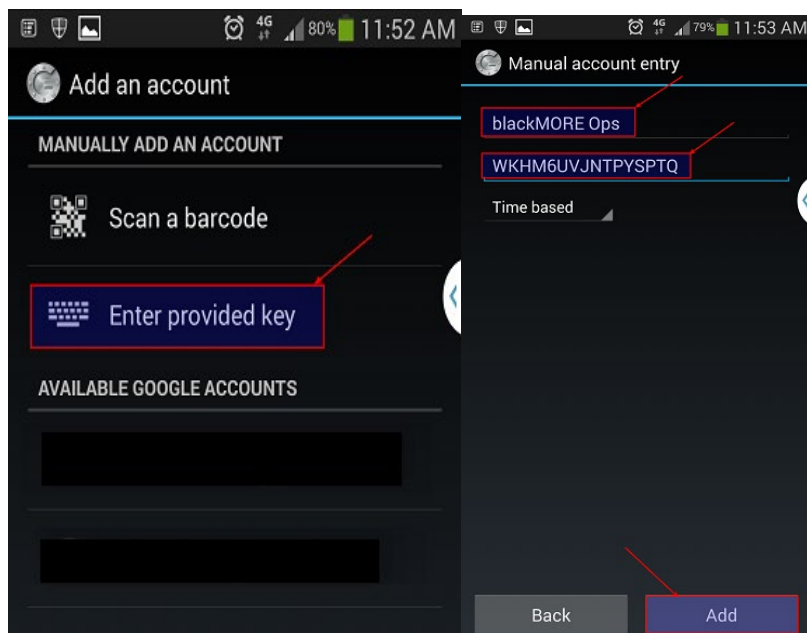
/etc/init.d/ssh restart

(or)
```

```
/etc/init.d/sshd restart
```

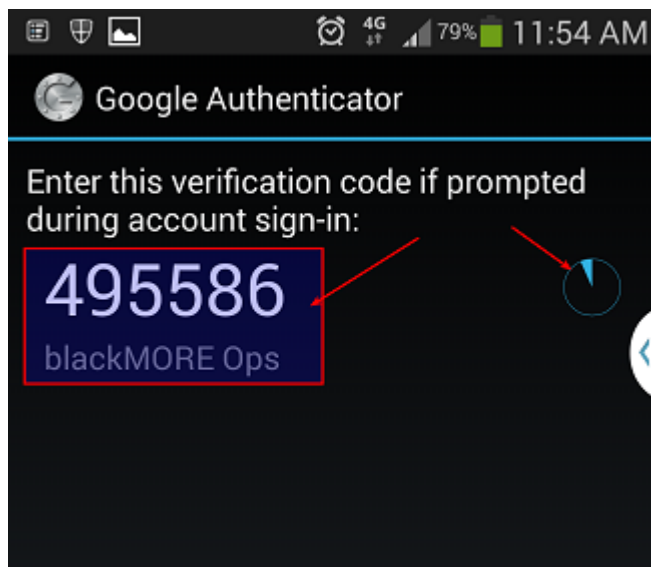
Step 6: Configure your SmartPhone for Google Authenticator App



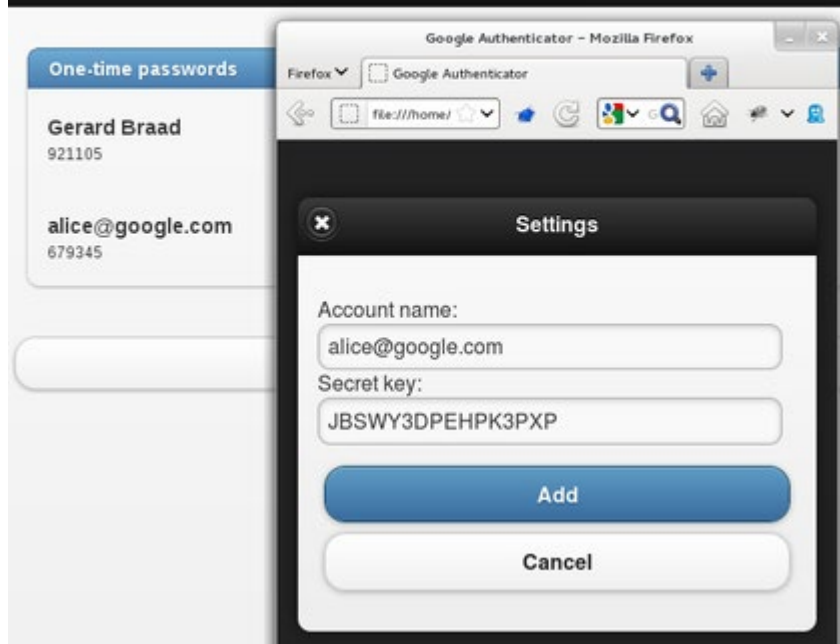
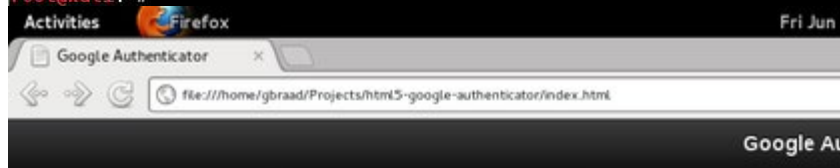


Step 7: Login to your computer via SSH

```
root@kali:~# ssh 127.0.0.1
```




```
root@kali: ~  
File Edit View Search Terminal Help  
root@kali:~#  
root@kali:~# ifconfig wlan0  
wlan0    Link encap:Ethernet  HWaddr 00:60:64:37:4a:30  
          inet addr:10.247.75.39  Bcast:10.247.75.255  Mask:255.255.252.0  
          inet6 addr: fe80::260:64ff:fe37:4a30/64 Scope:Link  
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1  
          RX packets:9568 errors:0 dropped:0 overruns:0 frame:0  
          TX packets:10078 errors:0 dropped:0 overruns:0 carrier:0  
          collisions:0 txqueuelen:1000  
          RX bytes:8402551 (8.0 MiB)  TX bytes:1606914 (1.5 MiB)  
  
root@kali:~# ssh 10.247.75.39  
The authenticity of host '10.247.75.39 (10.247.75.39)' can't be established.  
ECDSA key fingerprint is 90:8b:e8:7f:bb:87:b9:e2:31:d1:8a:5d:04:28:ef:73.  
Are you sure you want to continue connecting (yes/no)? yes  
Warning: Permanently added '10.247.75.39' (ECDSA) to the list of known hosts.  
Verification code:  
Password:  
Linux kali 3.14-kali1-amd64 #1 SMP Debian 3.14.5-1kali1 (2014-06-07) x86_64  
http://www.blackmoreops.com/  
  
[Kali Linux logo]  
  
http://www.blackmoreops.com/  
  
The programs included with the Kali GNU/Linux system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Kali GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent  
permitted by applicable law.  
Last login: Tue Jun 24 11:58:55 2014 from 10.247.75.39  
root@kali:~#
```



Q No 3

High (CVSS: 7.5) NVT: wpolson (nasl version) (OID: 1.3.6.1.4.1.25623.1.0.11139)		80/tcp
Summary		
This script attempts to use SQL injection techniques on CGI scripts		
More info at : http://en.wikipedia.org/wiki/SQL_injection		
Vulnerability Detection Result		
The following URLs seem to be vulnerable to various SQL injection techniques : /showforum.asp?id='UNION' /showforum.asp?id=' /showforum.asp?id='%22 /showforum.asp?id=9%2c+9%2c+9 /showforum.asp?id=9%2c+9%2c+9 /showforum.asp?id='bad_bad_value' /showforum.asp?id=bad_bad_value' /showforum.asp?id='+OR+' /showforum.asp?id='WHERE /showforum.asp?id=%3B /showforum.asp?id=%3B /showforum.asp?id='OR An attacker may exploit this flaws to bypass authentication or to take the control of the remote database. Solution: Modify the relevant CGIs so that they properly escape arguments See also : http://www.securiteam.com/securityreviews/5DP0N1P76E.html		
Solution		
Modify the relevant CGIs so that they properly escape arguments.		
Vulnerability Detection Method		
Details: wpolson (nasl version) (OID: 1.3.6.1.4.1.25623.1.0.11139)		
Version used: \$Revision: 421 \$		

Medium (CVSS: 5.0) NVT: IIS Service Pack - 404 (OID: 1.3.6.1.4.1.25623.1.0.11874)		80/tcp
Summary		
Ensure that the server is running the latest stable Service Pack		
Vulnerability Detection Result		
The remote IIS server *seems* to be Microsoft IIS 6.0 - w2k3 build 3790		
Solution		
Solution type: VendorFix		
The Patch level (Service Pack) of the remote IIS server appears to be lower than the current IIS service pack level. As each service pack typically contains many security patches, the server may be at risk.		
Caveat: This test makes assumptions of the remote patch level based on static return values (Content-Length) within the IIS Servers 404 error message. As such, the test can not be totally reliable and should be manually confirmed.		
Vulnerability Detection Method		
Details: IIS Service Pack - 404 (OID: 1.3.6.1.4.1.25623.1.0.11874)		
Version used: \$Revision: 1782 \$		

Log (CVSS: 0.0) NVT: OS fingerprinting (OID: 1.3.6.1.4.1.25623.1.0.102002)	general/tcp
Summary	
This script performs ICMP based OS fingerprinting (as described by Ofir Arkin and Fyodor Yarochkin in Phrack #57). It can be used to determine remote operating system version.	
Vulnerability Detection Result	
ICMP based OS fingerprint results: (100% confidence) Microsoft Windows	
Log Method	
Details: OS fingerprinting (OID: 1.3.6.1.4.1.25623.1.0.102002) Version used: \$Revision: 1739 \$	
References	
Other: http://www.phrack.org/issues.html?issue=57&id=7#article	
Log (CVSS: 0.0) NVT: ICMP Timestamp Detection (OID: 1.3.6.1.4.1.25623.1.0.103190)	general/icmp
Summary	
The remote host responded to an ICMP timestamp request. The Timestamp Reply is an ICMP message which replies to a Timestamp message. It consists of the originating timestamp sent by the sender of the Timestamp as well as a receive timestamp and a transmit timestamp. This information could theoretically be used to exploit weak time-based random number generators in other services.	
Vulnerability Detection Result	
Vulnerability was detected according to the Vulnerability Detection Method.	
Log Method	
Details: ICMP Timestamp Detection (OID: 1.3.6.1.4.1.25623.1.0.103190) Version used: \$Revision: 13 \$	
References	
CVE: CVE-1999-0524 CERT: DFN-CERT-2014-0658 Other: http://www.ietf.org/rfc/rfc0792.txt	

Q No 4

AES Encryption and Decryption in Python

1. Installation:

First, you need to install the `pycryptodome` library. You can install it using `pip`:

```
bash
pip install pycryptodome
```

2. Script:

```
from Crypto.Cipher import AES
from Crypto.Random import get_random_bytes
import base64
import os

# Function to pad the message to be a multiple of 16 bytes
def pad(message):
    # AES block size is 16 bytes, so we need to pad the message to a
    # multiple of 16
    padding = 16 - len(message) % 16
```

```

        return message + chr(padding) * padding

# Function to unpad the message
def unpad_message(message):
    padding = ord(message[-1])
    return message[:-padding]

# AES Encryption function
def encrypt_message(key, message):
    # Create a new AES cipher object using the key and a random IV
    # (Initialization Vector)
    iv = get_random_bytes(16)
    cipher = AES.new(key, AES.MODE_CBC, iv)

    # Pad the message to be a multiple of 16 bytes
    padded_message = pad_message(message)

    # Encrypt the message
    encrypted_message = cipher.encrypt(padded_message.encode())

    # Return the encrypted message and the IV (which is needed for
    # decryption)
    return base64.b64encode(iv + encrypted_message).decode()

# AES Decryption function
def decrypt_message(key, encrypted_message):
    # Decode the base64 encoded encrypted message
    encrypted_message = base64.b64decode(encrypted_message)

    # Extract the IV (first 16 bytes) and the encrypted message
    iv = encrypted_message[:16]
    encrypted_message = encrypted_message[16:]

    # Create a new AES cipher object with the same key and IV
    cipher = AES.new(key, AES.MODE_CBC, iv)

    # Decrypt the message and remove the padding
    decrypted_message = cipher.decrypt(encrypted_message).decode()
    return unpad_message(decrypted_message)

# Secure Key Management - Generating and saving keys securely
def generate_secure_key():
    return get_random_bytes(16) # AES-128 (16 bytes key)

# Example Usage:
if __name__ == '__main__':
    # Generate a secure AES key
    key = generate_secure_key()

    # Sample message to encrypt
    message = "This is a secret message."

    print(f"Original Message: {message}")

    # Encrypt the message
    encrypted = encrypt_message(key, message)
    print(f"Encrypted Message: {encrypted}")

    # Decrypt the message
    decrypted = decrypt_message(key, encrypted)
    print(f"Decrypted Message: {decrypted}")

```


Demonstrating Secure Key Management:

Importance of Secure Key Storage and Management:

1. **Key Confidentiality:** If the encryption key is compromised, attackers can decrypt the messages. Hence, it's crucial to store the encryption keys in a secure environment, such as a key management system (KMS) or hardware security module (HSM).
2. **Key Rotation:** Over time, keys may need to be changed (key rotation) to minimize the risk of long-term exposure. Secure key management includes automated mechanisms for key rotation.
3. **Access Control:** Keys should only be accessible to authorized personnel and systems. Access control policies should ensure that only trusted applications or users can use or retrieve the keys.
4. **Encryption of Keys:** To add another layer of security, the keys themselves can be encrypted and stored securely. For example, using a master key to encrypt other keys ensures the keys are not stored in plaintext.
5. **Auditability:** Secure key management systems should offer logging and auditing capabilities to track when and how keys are accessed, ensuring traceability and accountability.

Q No 5

CaseStudy: The MOVEit Data Breach (2023)

Introduction

In May 2023, a major cybersecurity incident involving Progress Software's **MOVEit Transfer**, a file-transfer application, affected several organizations globally. The breach, attributed to the Clop ransomware group, exposed sensitive data across industries, including financial institutions, government agencies, and healthcare organizations. The attack highlights critical vulnerabilities in widely-used enterprise software, showcasing the importance of proactive cybersecurity measures.

Nature of the Attack

The MOVEit breach was a **supply chain attack** exploiting a previously unknown **zero-day vulnerability** in the MOVEit Transfer software. The attackers targeted organizations using the platform for secure file sharing. By leveraging SQL injection, the attackers gained unauthorized access to MOVEit instances, exfiltrating data before organizations could detect the intrusion.

The Clop group employed their typical "double extortion" method:

1. Threatening to publish stolen data unless a ransom was paid.
2. Exfiltrating and encrypting critical data, amplifying the pressure on victims.

Vulnerabilities Exploited

The key vulnerability exploited was a **SQL injection flaw** (CVE-2023-34362). This allowed the attackers to execute malicious SQL queries, granting them:

1. **Unauthenticated access** to sensitive data.
2. Control over application servers.
3. Capability to escalate privileges within the system.

The root causes included:

- Lack of input validation and sanitization in the software.
- Organizations not patching their MOVEit systems promptly due to lack of awareness of the vulnerability's existence.

Impact and Resolution

Impact:

The attack had wide-reaching consequences:

- **Data Exfiltration:** Sensitive data, including financial records, personal information, and business details, was stolen.

- **Economic Losses:** Many organizations faced significant financial losses due to operational disruptions, ransom demands, and breach mitigation costs.
- **Reputation Damage:** Victim organizations suffered reputational harm, impacting customer trust.
- **Regulatory Penalties:** Non-compliance with data protection laws (e.g., GDPR, HIPAA) resulted in fines for some entities.

Resolution:

1. **Emergency Patches:** Progress Software released patches for the MOVEit vulnerability within days of its discovery.
2. **Incident Response:** Organizations took immediate action to disconnect affected systems, assess the extent of data theft, and engage third-party cybersecurity firms for remediation.
3. **Law Enforcement Involvement:** Agencies like the FBI and CISA provided guidance and investigated the Clop group's activities.

Preventive Measures

1. **Proactive Vulnerability Management:**
 - Conduct regular vulnerability assessments and penetration testing to identify weaknesses.
 - Establish rapid patch deployment procedures for critical systems.
2. **Input Validation and Secure Coding Practices:**
 - Employ input validation techniques to prevent SQL injection attacks.
 - Adhere to secure software development lifecycle (SDLC) practices.
3. **Network Segmentation and Least Privilege:**
 - Isolate critical infrastructure from less secure systems to limit attack scope.
 - Implement the principle of least privilege to minimize access rights.
4. **Monitoring and Threat Detection:**
 - Deploy intrusion detection/prevention systems (IDS/IPS) to identify malicious activity.
 - Use behavioral analytics to detect unusual access patterns or data exfiltration attempts.
5. **Third-Party Vendor Management:**
 - Conduct security assessments of third-party software providers.
 - Require vendors to disclose vulnerabilities and adhere to strict cybersecurity standards.
6. **Regular Security Training:**
 - Train employees and IT staff on emerging threats, secure configurations, and incident response protocols.

Conclusion

The MOVEit data breach underscores the critical importance of robust cybersecurity measures, particularly in managing third-party software. By adopting proactive vulnerability management, secure coding practices, and continuous monitoring, organizations can mitigate the risk of similar attacks. While the attack caused significant disruption, it serves as a stark reminder of the evolving threat landscape and the need for vigilance in defending against cyber threats.